31_SECURITY.md

UNPLND Security & Privacy Specification

Version 1.0

Priority: CRITICAL

Status: MVP

Purpose

Security is not optional.

Privacy is not a feature.

Trust is the foundation of UNPLND.

Users share sensitive context:

Location.

Photos.

Plans.

Memories.

Friends.

Preferences.

This data must be protected by default.

Security Philosophy

Collect less.

Store less.

Expose less.

Protect more.

UNPLND should only collect data that directly improves the user experience.

Core Security Principles

Least privilege.

Server-side validation.

Encrypted transport.

Secure storage.

No secrets in client apps.

Privacy by default.

User control.

Authentication

Use Firebase Authentication.

Supported providers:

Apple

Google

Email

Optional guest mode

Every protected request requires a valid auth token.

Never trust unauthenticated user IDs.

Authorization

Every document must have an owner.

Users may only access:

their own plans

their own albums

their own profile

their own favorites

shared albums explicitly shared with them

Never rely only on client-side checks.

Firebase Security Rules

Firestore rules must enforce:

ownerId == request.auth.uid

for private user data.

Storage rules must enforce:

user can only access their own files

unless shared access is granted.

API Security

Every API endpoint validates:

authentication

authorization

input schema

rate limit

allowed values

ownership

Never process raw unvalidated client data.

Secrets

Never store in app code:

API keys

AI provider keys

Maps server keys

Firebase admin keys

Payment secrets

All sensitive provider calls happen server-side.

Location Privacy

Location is sensitive.

Use only when needed.

Track only during active planning or active evening.

Never continuously background track without explicit consent.

Never sell location data.

Never expose precise location in shared content by default.

Shared Albums

Default:

Private.

When sharing:

reduce exact location precision

remove sensitive metadata if needed

allow link revocation

allow deletion

Users control what is shared.

Photos

Never upload photos automatically without user action.

Never analyze photos without consent.

Never share photos by default.

Never expose original metadata publicly unless required.

Data Minimization

Do not collect:

gender

birthday

private contacts

unnecessary demographic data

precise long-term location history

unless explicitly required for a feature.

GDPR

Support:

Data export

Data deletion

Consent management

Privacy policy

Purpose limitation

Data minimization

Right to revoke consent

Deletion must be real.

Not fake.

Account Deletion

When user deletes account:

Delete user profile.

Delete private plans.

Delete albums.

Delete photos.

Delete favorites.

Delete notification tokens.

Anonymize analytics where possible.

Rate Limiting

Protect:

AI plan generation

search

feedback

album creation

authentication attempts

Prevent abuse.

Prevent cost attacks.

App Check

Enable Firebase App Check.

Protect backend resources.

Block unauthorized clients.

Secure Storage

Use secure storage for sensitive tokens.

Never store tokens in plain local storage.

Never store passwords.

Network

HTTPS only.

No insecure HTTP.

Timeouts required.

Retry safely.

No sensitive data inside URLs.

Logging

Allowed:

request id

latency

error code

feature name

Not allowed:

passwords

tokens

photo contents

private notes

exact location logs

raw AI prompts with user-sensitive data

AI Privacy

Only send necessary context.

Do not send private notes unless needed.

Do not send photos unless explicitly approved.

Do not store raw prompts longer than necessary.

Partner Privacy

Partners never receive personal user data by default.

Partner analytics are aggregated.

No exact user identities.

No exact private routes.

Permissions

Ask only when needed.

Explain before asking.

Location

Photos

Notifications

Camera

Never request all permissions at once.

Security Incident Response

If breach suspected:

Disable affected feature.

Rotate secrets.

Notify users if required.

Investigate.

Document.

Fix.

Review.

Threats

Main threats:

API key leakage

Firestore rule misconfiguration

AI cost abuse

Unauthorized album access

Location privacy issues

Account takeover

Malicious links

Security Testing

Required:

Firestore rules tests

API authorization tests

Input validation tests

Storage access tests

Account deletion tests

Rate limit tests

DO NOT

Do NOT expose secrets.

Do NOT trust the client.

Do NOT over-collect data.

Do NOT make albums public by default.

Do NOT track users outside active usage.

Do NOT sell user data.

Do NOT hide privacy controls.

Delight Checklist

✓ Users feel safe.

✓ Privacy controls are clear.

✓ Sharing feels controlled.

✓ Permissions feel justified.

✓ Trust is never broken.

Golden Rule

Trust is harder to build than features.

Protect it before anything else.

Claude Instructions

Every feature must define its security and privacy behavior.

If ownership is unclear,

do not implement.

If data access is unclear,

do not implement.

Privacy wins over convenience.

Always.

END OF 31_SECURITY.md